SE LAB 5

NAME: Vankadara Sri Kruthi

SRN: PES2UG24CS574

CLASS: 5J

GITHUB LINK: https://github.com/kruthivankadara-dev/L5_14_recruitment_tracker

Screenshot 1 — Installation and original program

```
PS C:\Users\srikr\Downloads\L5_14_recruitment_tracker> python --version
>> python recruitment_tracker.py
Python 3.11.9
['Nina']
2 in interview
```

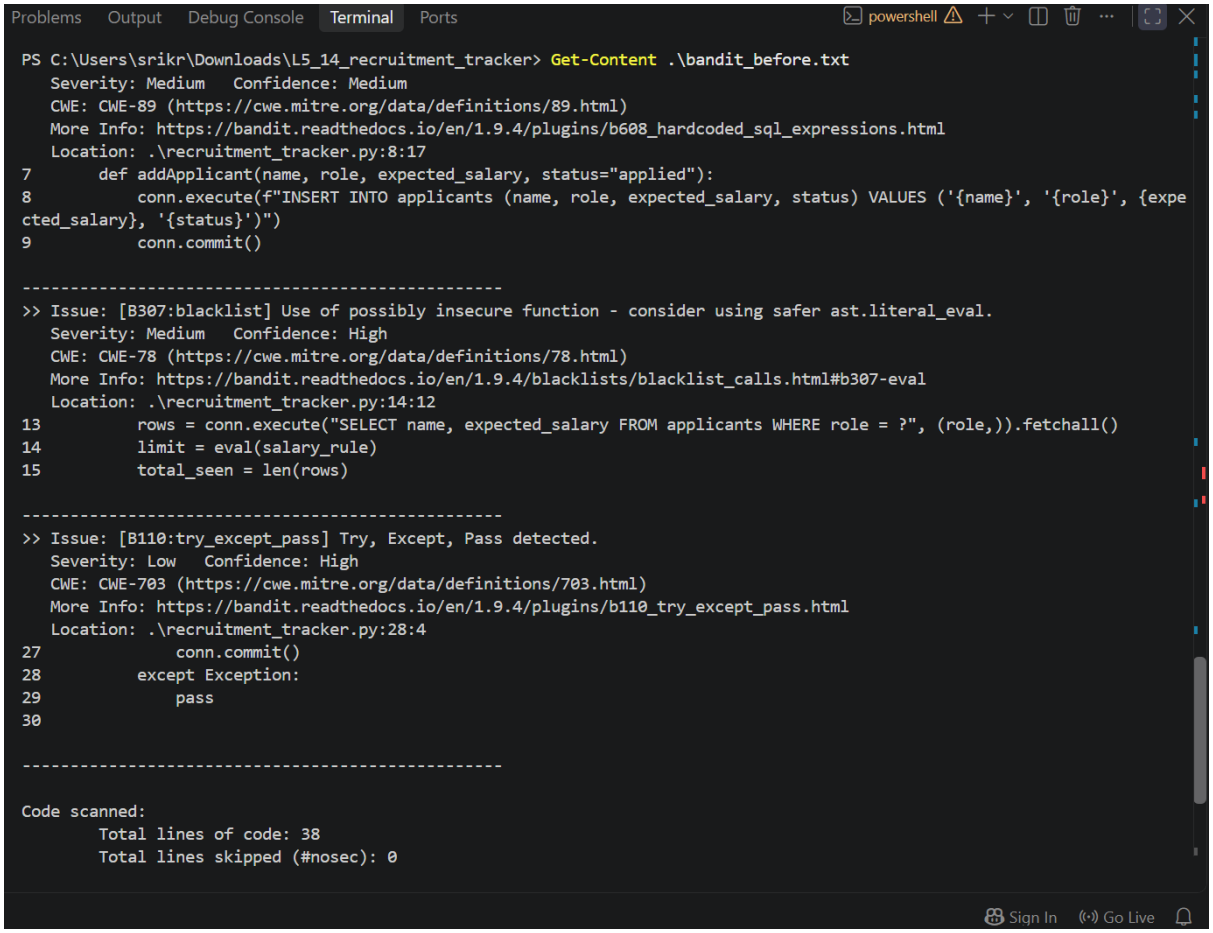
Screenshot 2 — Pylint BEFORE report

```
PS C:\Users\srikr\Downloads\L5_14_recruitment_tracker> Get-Content .\pylint_before.txt
************* Module recruitment_tracker
recruitment_tracker.py:4:0: C0301: Line too long (124/100) (line-too-long)
recruitment_tracker.py:8:0: C0301: Line too long (140/100) (line-too-long)
recruitment_tracker.py:13:0: C0301: Line too long (106/100) (line-too-long)
recruitment_tracker.py:15:26: C0303: Trailing whitespace (trailing-whitespace)
recruitment_tracker.py:1:0: C0114: Missing module docstring (missing-module-docstring)
recruitment_tracker.py:7:0: C0116: Missing function or method docstring (missing-function-docstring)
recruitment_tracker.py:7:0: C0103: Function name "addApplicant" doesn't conform to snake_case naming style (invalid-name)
recruitment_tracker.py:12:0: C0116: Missing function or method docstring (missing-function-docstring)
recruitment_tracker.py:14:12: W0123: Use of eval (eval-used)
recruitment_tracker.py:12:0: R1710: Either all return statements in a function should return an expression, or none of th
em should. (inconsistent-return-statements)
recruitment_tracker.py:15:4: W0612: Unused variable 'total_seen' (unused-variable)
recruitment_tracker.py:24:0: C0116: Missing function or method docstring (missing-function-docstring)
recruitment_tracker.py:24:0: C0103: Function name "updateStatus" doesn't conform to snake_case naming style (invalid-name
)
recruitment_tracker.py:28:11: W0718: Catching too general exception Exception (broad-exception-caught)
recruitment_tracker.py:31:0: C0116: Missing function or method docstring (missing-function-docstring)
recruitment_tracker.py:31:0: C0103: Function name "exportReport" doesn't conform to snake_case naming style (invalid-name
)
recruitment_tracker.py:32:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
recruitment_tracker.py:32:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
recruitment_tracker.py:38:0: C0116: Missing function or method docstring (missing-function-docstring)
recruitment_tracker.py:38:0: C0103: Function name "countByStatus" doesn't conform to snake_case naming style (invalid-nam
e)
recruitment_tracker.py:42:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 4.47/10

PS C:\Users\srikr\Downloads\L5_14_recruitment_tracker>
```

Screenshot 3 — Bandit BEFORE report



```
Problems  Output  Debug Console  Terminal  Ports                                  powershell

PS C:\Users\srikr\Downloads\L5_14_recruitment_tracker> Get-Content .\bandit_before.txt
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\recruitment_tracker.py:8:17
7       def addApplicant(name, role, expected_salary, status="applied"):
8           conn.execute(f"INSERT INTO applicants (name, role, expected_salary, status) VALUES ('{name}', '{role}', {expe
cted_salary}, '{status}')")
9           conn.commit()

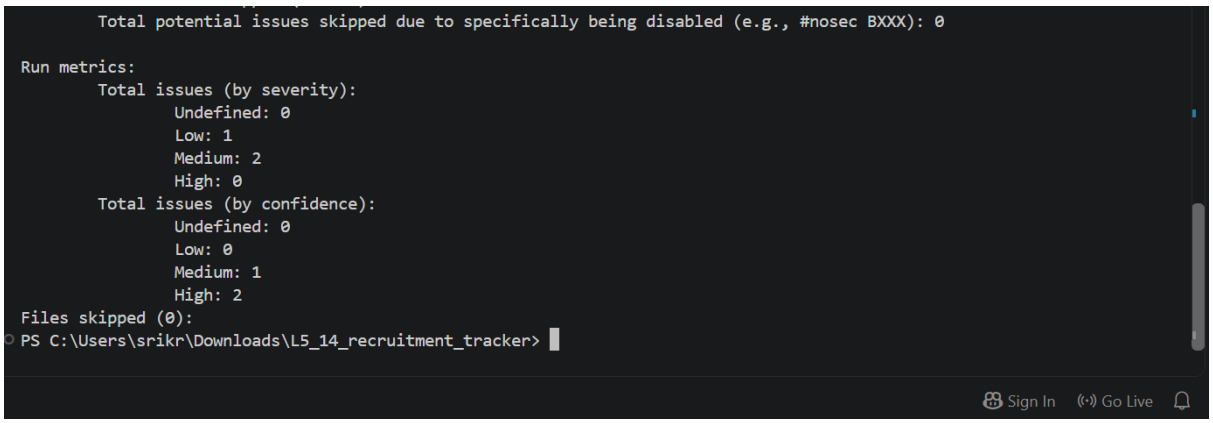
--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\recruitment_tracker.py:14:12
13          rows = conn.execute("SELECT name, expected_salary FROM applicants WHERE role = ?", (role,)).fetchall()
14          limit = eval(salary_rule)
15          total_seen = len(rows)

--------------------------------------------------
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\recruitment_tracker.py:28:4
27              conn.commit()
28          except Exception:
29              pass
30

--------------------------------------------------

Code scanned:
        Total lines of code: 38
        Total lines skipped (#nosec): 0

                                                                    Sign In  Go Live
```

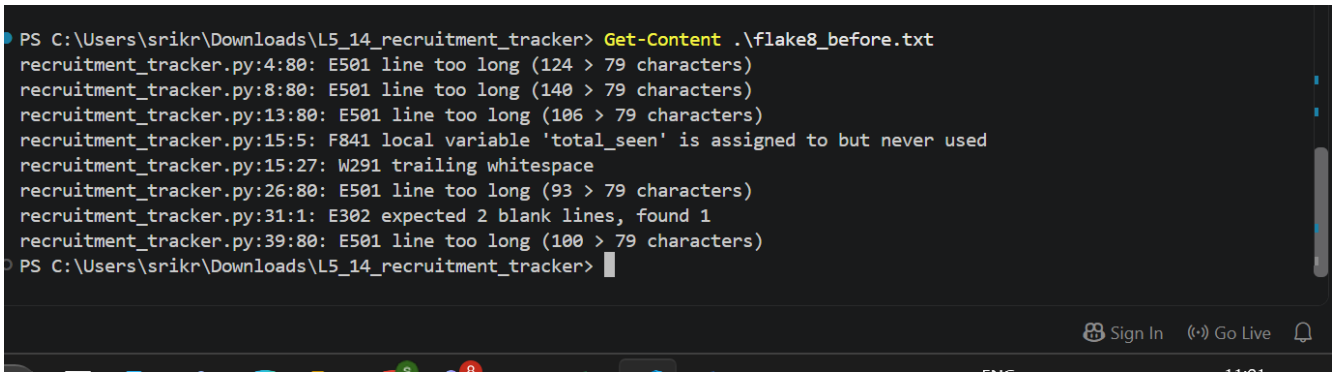


```
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

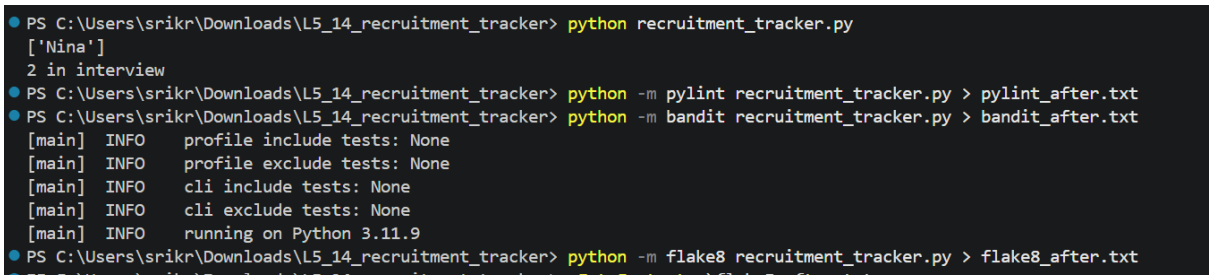
Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 1
                Medium: 2
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 2
Files skipped (0):
PS C:\Users\srikr\Downloads\L5_14_recruitment_tracker>

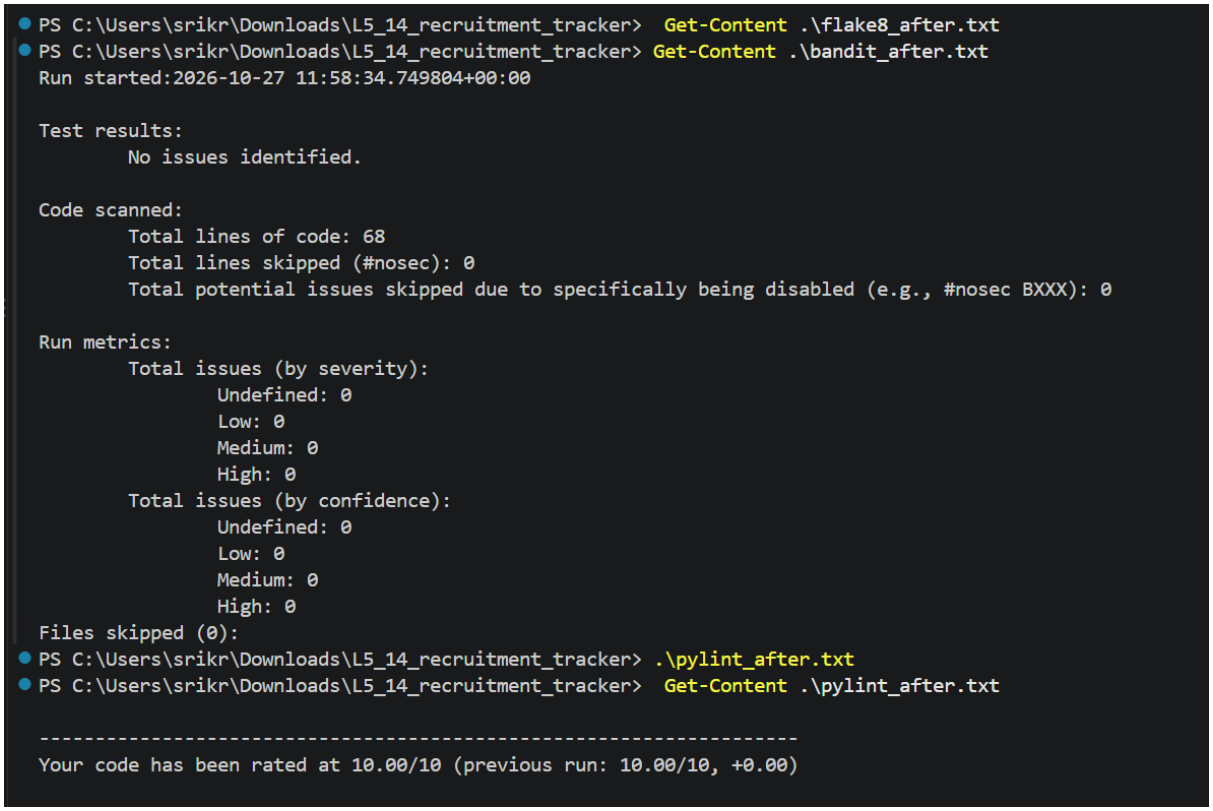
                                                                    Sign In  Go Live
```

Screenshot 4 — Flake8 BEFORE report



three AFTER reports





recruitment_tracker.py :

```
"""Recruitment tracker with SQLite storage and applicant shortlisting."""
import sqlite3

conn = sqlite3.connect(":memory:")
conn.execute(
    """
    CREATE TABLE applicants (
        id INTEGER PRIMARY KEY,
        name TEXT,
        role TEXT,
        expected_salary INTEGER,
        status TEXT
    )
    """
)


def add_applicant(name, role, expected_salary, status="applied"):
    """Add a new applicant to the database."""
    conn.execute(
        """
        INSERT INTO applicants (name, role, expected_salary, status)
        VALUES (?, ?, ?, ?)
        """,
        (name, role, expected_salary, status),
    )
    conn.commit()


def shortlist(role, salary_limit):
    """Return applicants for a role within the specified salary limit."""
    rows = conn.execute(
        "SELECT name, expected_salary FROM applicants WHERE role = ?",
        (role,),
    ).fetchall()

    result = []
    for name, salary in rows:
        if salary <= salary_limit:
            result.append(name)

    return result


def update_status(applicant_id, status):
    """Update the recruitment status of an applicant."""
    try:
        conn.execute(
            "UPDATE applicants SET status = ? WHERE id = ?",
```

```
            (status, applicant_id),
        )
        conn.commit()
    except sqlite3.Error as error:
        conn.rollback()
        print(f"Database error while updating status: {error}")


def export_report(path):
    """Export applicant names, roles, and statuses to a CSV file."""
    with open(path, "w", newline="", encoding="utf-8") as file:
        for row in conn.execute(
            "SELECT name, role, status FROM applicants"
        ):
            file.write(",".join(str(value) for value in row) + "\n")


def count_by_status(status):
    """Return the number of applicants with the specified status."""
    query = "SELECT COUNT(*) FROM applicants WHERE status = ?"
    result = conn.execute(query, (status,)).fetchone()
    return result[0]


def main():
    """Run the recruitment tracker demonstration."""
    add_applicant("Nina", "analyst", 600000)
    add_applicant("Omar", "analyst", 750000, "interview")
    add_applicant("Priya", "developer", 900000)
    update_status(1, "interview")
    print(shortlist("analyst", 650000))
    export_report("applicants_report.csv")
    print(count_by_status("interview"), "in interview")


main()
```

issues.md :

recruitment_tracker.py | 07_After_Pylint_Bandit_Flake8_Report.png | issues.md

issues.md > # Lab 5 — Static Code Analysis > ## Validation Plan

```
# Lab 5 – Static Code Analysis

## Issues Identified

| ID | Tool | Location | Issue | Proposed Fix |
|---|---|---|---|---|
| I-01 | Bandit | `addApplicant()` | SQL query constructed using an f-string | Replace string interpolation with parameterized SQL. |
| I-02 | Bandit | `shortlist()` | Use of `eval()` to process the salary rule | Accept a numeric salary limit instead of evaluating Python expressions. |
| I-03 | Bandit / Pylint | `updateStatus()` | Broad exception handling silently suppresses errors | Catch an appropriate database exception and handle it explicitly. |
| I-04 | Pylint | `exportReport()` | File opened without a context manager | Use `with open(...)` to ensure the file is closed. |
| I-05 | Pylint | Multiple functions | Function names do not follow `snake_case` | Rename functions to conventional Python names. |
| I-06 | Flake8 | Line 15 | Unused `total_seen` variable | Remove the unused variable. |
| I-07 | Flake8 | Multiple lines | Long lines, trailing whitespace and incorrect spacing | Reformat the affected code. |
| I-08 | Functional correctness | `shortlist()` | Returns `None` if no candidates meet the salary limit | Return an empty list when there are no matches. |

## Validation Plan

1. Run the original program and record its output.
2. Save the initial Pylint, Bandit and Flake8 reports.
3. Implement and document the fixes.
4. Rerun all three tools and save their final reports.
5. Run the corrected program and verify its output.
6. Record the Git commits and summarize the results.
```

reflection.md :

```
# Lab 5 – Reflection on Static Code Analysis

## 1. What is the purpose of using static code analysis tools?

Static code analysis tools help identify potential issues in source code
without executing the program. In this lab, Pylint was used to check code
quality and coding conventions, Bandit was used to identify potential security
vulnerabilities, and Flake8 was used to detect style violations and formatting
problems. Using these tools helped us improve the readability,
maintainability, and security of the recruitment tracker.

## 2. What issues were identified in the original program?

The original program contained several issues, including SQL queries
constructed using string formatting, the use of `eval()` to process salary
```

rules, broad exception handling, and file handling without a context manager. It also had inconsistent function naming, unused variables, and formatting violations. Additionally, the shortlist function did not consistently return an appropriate value when no applicants matched the salary criteria.

3. How were the identified issues fixed?

The SQL queries were modified to use parameterized statements, reducing the risk of SQL injection. The use of `eval()` was removed and replaced with a numeric salary limit. Exception handling was improved to handle database errors explicitly, and file operations were updated to use a context manager. Function names were converted to `snake_case`, unused variables were removed, and formatting issues were corrected. The shortlist function was also updated to return an empty list when no applicants matched the criteria.

4. What did you learn from this lab, and how did you verify the improvements?

This lab helped me understand that a program can produce the expected output while still containing security vulnerabilities and code quality issues. Different static analysis tools identify different categories of problems, so using Pylint, Bandit, and Flake8 together provides broader coverage. After making the corrections, I reran the tools and executed the program to verify the changes. The final Pylint report achieved a score of 10/10, Bandit reported no issues, and the corrected program produced the expected output. This demonstrated the value of combining automated analysis with functional testing.

Commits:

